

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ESPECIFICACIÓN DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión: 1	Fecha: 27/07/2026

Documento de Especificación de Arquitectura

Realizado por:

Michael David Rodriguez Beltran

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

HISTORIAL DE REVISIONES

Fecha	Versión	Autor	Descripción	Revisado Por
24/07/2026	1.0	Michael R.	Documento de arquitectura del proyecto portfolio (codebymike.tech)	Michael R.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

Contenido

1. Documento de Arquitectura de Software

- 1.1 Introducción
- 1.2 Propósito
- 1.3 Alcance
- 1.4 Requerimientos no funcionales
- 1.5 Definiciones, acrónimos y abreviaciones

2. Generalidades del Proyecto

- 2.1 Justificación
- 2.2 Problema a resolver
- 2.3 Objetivos
- 2.4 Descripción general del sistema
- 2.5 Identificación de los Stakeholders y sus responsabilidades

3. Vistas de la Arquitectura

- 3.1 Vista de casos de uso
- 3.2 Vista de procesos
- 3.3 Vista lógica
- 3.4 Vista de implementación
- 3.5 Vista de despliegue
- 3.6 Arquitectura en capas
- 3.7 Vista de datos

4. Definición de Interfaces de Usuario

5. Características Generales de Calidad

- 5.1 Tamaño y performance
 - 5.2 Calidad
 - 5.3 Usabilidad
 - 5.4 Eficiencia
 - 5.5 Seguridad
 - 5.6 Confiabilidad
 - 5.7 Mantenibilidad
- Evidencia técnica: normas y estándares aplicables

Documento de Arquitectura de Software

1.1 Introducción

Este documento describe la arquitectura del portafolio profesional y panel de control privado de Codebymike, publicado en codebymike.tech. El proyecto combina un sitio público (proyectos, notas técnicas, estado del sistema, herramientas), un panel administrativo privado que funciona como CRM + control de costos/rentabilidad + bóveda de credenciales + observabilidad, un portal de clientes independiente, una pasarela de pagos con idempotencia real, un micro-SIEM propio de seguridad perimetral, y un laboratorio de ingeniería ("LAB") donde se practican y documentan disciplinas de CI/CD, chaos engineering, SRE y testing avanzado como evidencia técnica para la formación SENA del autor.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

El sistema está construido sobre Astro 6 en modo SSR (Server-Side Rendering) con adaptador de Vercel, Turso/libSQL como base de datos vía Drizzle ORM, Auth.js con GitHub OAuth para el panel administrativo, y Tailwind 4 para la capa visual. Deliberadamente no se usan frameworks de frontend adicionales ni servicios de pago de terceros distintos a Wompi: monitoreo, alertas, SLOs y observabilidad de seguridad son desarrollo propio.

El alcance de este documento cubre la definición de la arquitectura del sistema completo: vistas de casos de uso, de procesos, lógica, de implementación, de despliegue y de datos, junto con las características de calidad necesarias para un producto que procesa pagos reales, credenciales cifradas y datos de clientes.

Las secciones siguientes detallan las generalidades del proyecto (justificación, problema que resuelve, objetivos), identifican a los stakeholders involucrados y describen el sistema en su totalidad, sirviendo como guía de referencia sobre por qué el sistema está estructurado como está.

1.2 Propósito

El objetivo de este documento es definir y analizar la arquitectura de un sistema que cumple, simultáneamente, tres funciones: vitrina profesional pública verificable con datos reales, herramienta operativa diaria de gestión de proyectos freelance/consultoría, y laboratorio de prácticas de ingeniería de software avanzada con evidencia trazable.

Se incluyen diagramas de casos de uso, actividades, estados, secuencia, componentes, paquetes, despliegue y el modelo relacional de datos, para ilustrar tanto la interacción del usuario con el sistema como las decisiones estructurales internas.

1.3 Alcance

Este sistema está diseñado para un profesional independiente que necesita mostrar su trabajo públicamente, gestionar clientes y proyectos activos, cobrar de forma segura e idempotente, y mantener visibilidad operativa (uptime, seguridad, costos) sin depender de herramientas SaaS de terceros para cada función.

Limitaciones del alcance

- El panel administrativo tiene un único administrador autorizado (allowlist de un solo login de GitHub); no hay roles ni permisos granulares.
- El portal de clientes es de solo lectura/interacción limitada (facturas, hitos, documentos, mensajería); no reemplaza herramientas de gestión de proyecto completas.
- La pasarela de pagos (Wompi) cubre Colombia; no hay soporte multi-gateway ni multi-región.
- El módulo LAB documenta prácticas de ingeniería con fines educativos además de su función operativa real; algunas fases (pruebas de carga k6, parte de SAST/a11y automatizado) están planeadas pero no implementadas.

Usuarios objetivo

- El administrador único del sistema es Michael Rodriguez, vía el panel /admin.
- Clientes de proyectos activos, vía el portal /portal y el checkout de pagos.
- Visitantes públicos: reclutadores, clientes potenciales, buscadores.
- Sistemas automatizados: crons externos, la pasarela de pagos, motores de búsqueda.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

1.4 Requerimientos no funcionales

Los requerimientos no funcionales están catalogados y versionados como código en src/data/documentacion.ts, organizados según las categorías de ISO/IEC 25010.

Categoría	Resumen
Seguridad	Cifrado de secretos en reposo (AES-256-GCM), autorización por allowlist, fail-open en todo el enforcement de seguridad, TTL obligatorio en bloqueos.
Confiabilidad y disponibilidad	Idempotencia de pagos, máquina de estados sin retrocesos, rollback automático de deploy, SLO configurable por monitor.
Eficiencia de desempeño	Sensor de seguridad sin latencia perceptible, cache en memoria de 30s para blocklist/chaos, Core Web Vitals en banda 'good' (parcial).
Mantenibilidad	Requerimientos y casos de uso como código TypeScript tipado; ADR por proyecto; purga de datos operativos a 90 días.
Usabilidad y accesibilidad	Panel operable desde móvil; auditoría de accesibilidad automatizada por PR (planeada).

1.5 Definiciones, acrónimos y abreviaciones

ARQUITECTURA DE SOFTWARE: Conjunto de elementos estáticos del diseño intelectual del sistema que dan forma al código fuente y al comportamiento en tiempo de ejecución.

SSR (Server-Side Rendering): Renderizado del HTML en el servidor en cada request; Astro se configura con output: 'server' en este proyecto.

ORM (Object-Relational Mapping): Capa de mapeo entre objetos TypeScript y tablas SQL; aquí, Drizzle ORM sobre libSQL/Turso.

SIEM (Security Information and Event Management): Sistema de correlación y respuesta a eventos de seguridad; implementado como micro-SIEM propio en src/lib/security/.

Idempotencia: Propiedad por la cual ejecutar una operación más de una vez con los mismos parámetros produce el mismo resultado que ejecutarla una sola vez.

Fail-open: Filosofía de diseño en la que, si un mecanismo de seguridad falla internamente, el sistema deja pasar el request en vez de bloquearlo.

TTL (Time To Live): Tiempo de vida obligatorio de un dato temporal (bloqueo de IP, flag de chaos, sesión de demo).

Webhook: Notificación HTTP asíncrona que un sistema externo envía ante un evento, en este caso el resultado de una transacción.

AsyncLocalStorage: Mecanismo de Node.js usado para propagar contexto (modo demo o no) a través de llamadas asíncronas.

P&L (Profit & Loss): Cálculo de rentabilidad por proyecto contrastando ingresos cobrados contra costos de servicios asociados.

STAKEHOLDER: Individuo, equipo o sistema con intereses relativos al sistema.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

2. Generalidades del Proyecto

2.1 Justificación

Todo trabajo freelance/consultoría independiente enfrenta el mismo problema estructural: demostrar competencia técnica real es difícil cuando la evidencia vive detrás de NDAs de clientes o en repositorios privados inaccesibles. Este proyecto resuelve ese problema construyendo la evidencia directamente: la página /status muestra uptime real de monitores en producción, /security expone hallazgos reales de auditoría (SAST, CodeQL, npm audit) con su commit de corrección, y /lab expone métricas reales de un pipeline de CI/CD con rollback automático. No son mockups — son datos agregados de un sistema que además cumple una función operativa real: gestionar clientes, cobrar y facturar.

Construir y mantener el propio motor de observabilidad, el propio micro-SIEM y la propia máquina de estados de pagos, en vez de delegar en SaaS de terceros, es una decisión deliberada de aprendizaje: cada uno de esos subsistemas encierra problemas de ingeniería no triviales (idempotencia bajo concurrencia, fail-open en seguridad, rate limiting resistente a redeployes).

2.2 Problema a resolver

Un profesional independiente que gestiona varios proyectos simultáneos necesita: saber cuánto le cuesta cada proyecto y cuánto margen real deja, tener un lugar donde el cliente vea el avance sin pedir actualizaciones por WhatsApp, cobrar de forma segura sin duplicar cargos ante fallas de red, y detectar cuándo un servicio propio cae antes de que el cliente lo note. Resolver cada uno de estos problemas con herramientas SaaS separadas multiplica costos fijos mensuales y fragmenta los datos entre sistemas que no se hablan entre sí.

Adicionalmente, la superficie pública de internet expone cualquier sitio a tráfico hostil constante; sin un sensor propio, esos eventos pasan desapercibidos hasta que causan daño. Y sin un pipeline con verificación post-deploy, un despliegue roto puede quedar en producción horas antes de ser detectado manualmente.

2.3 Objetivos

General:

Construir y operar un sistema integral (portafolio público + panel de control privado + laboratorio de ingeniería) que centralice la gestión de proyectos, clientes, finanzas y seguridad de un profesional independiente, sirviendo simultáneamente como evidencia técnica verificable de sus capacidades de ingeniería de software.

Específicos:

1. Proveer un CRM interno para gestionar proyectos, clientes, briefings, seguimiento comercial y decisiones de arquitectura (ADRs) por proyecto.
2. Calcular la rentabilidad real (P&L) de cada proyecto contrastando costos de servicios contra ingresos cobrados, en múltiples monedas.
3. Ofrecer un portal de clientes aislado por cuenta, con facturación, hitos, documentos y mensajería, sin exponer datos entre clientes distintos.
4. Procesar pagos con idempotencia garantizada, verificación de firma del gateway y una máquina de estados sin retrocesos ante eventos duplicados o fuera de orden.
5. Detectar y responder automáticamente a tráfico hostil mediante un micro-SIEM propio, con enforcement fail-open.
6. Monitorear la disponibilidad de servicios propios y de clientes, calculando SLOs y notificando incidentes en tiempo real.
7. Practicar y documentar disciplinas de ingeniería avanzada (chaos engineering, CI/CD con rollback automático, mutation testing) como evidencia técnica trazable para la formación SENA del autor.

2.4 Descripción general del sistema

El sistema se construye como una aplicación Astro 6 con renderizado en servidor (SSR), desplegada en Vercel bajo el dominio codebymike.tech, con Turso (libSQL) como base de datos vía Drizzle ORM. La aplicación expone tres superficies claramente separadas, cada una con su propio sistema de autenticación sin compartir cookies ni lógica entre sí: sitio público, panel administrativo (/admin) y portal de clientes (/portal).

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026

Un cuarto modo, la demo pública (/demo), permite explorar una réplica de solo lectura del panel admin sin credenciales, apuntando a una instancia separada de Turso (aislamiento real de datos) seleccionada mediante un AsyncLocalStorage que envuelve cada request.

Toda la capa de seguridad perimetral (middleware) opera antes de llegar a cualquier página: clasifica el request contra firmas conocidas de ataque, aplica rate limiting de dos capas, consulta una blocklist de IPs con TTL escalado, y decide el enforcement de forma fail-open.

2.5 Identificación de los Stakeholders y sus responsabilidades

Stakeholder	Descripción	Responsabilidad / Escenario
Administrador (Mike)	Único usuario con acceso al panel completo.	Gestiona proyectos, clientes, finanzas, seguridad y el LAB; responde a incidentes.
Cliente	Persona de negocio de un proyecto gestionado.	Revisa facturas, hitos y documentos; envía mensajes; realiza pagos.
Visitante público	Reclutador, cliente potencial o buscador.	Consulta proyectos, estado del sistema, notas técnicas; explora la demo.
Cron externo	Disparador automático periódico (cron-job.org / Vercel Cron).	Ejecuta chequeos de uptime, backups, rollups de seguridad, vencimientos.
Pasarela de pagos (Wompi)	Sistema externo que procesa transacciones.	Notifica el resultado de cada transacción vía webhook firmado.
Buscador (Google/Bing)	Rastreador que indexa el contenido público.	Consume sitemap, RSS y recibe notificaciones IndexNow.
GitHub (CI/CD)	Plataforma de repositorio y automatización.	Ejecuta el pipeline de calidad, seguridad, accesibilidad y mutation testing.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026

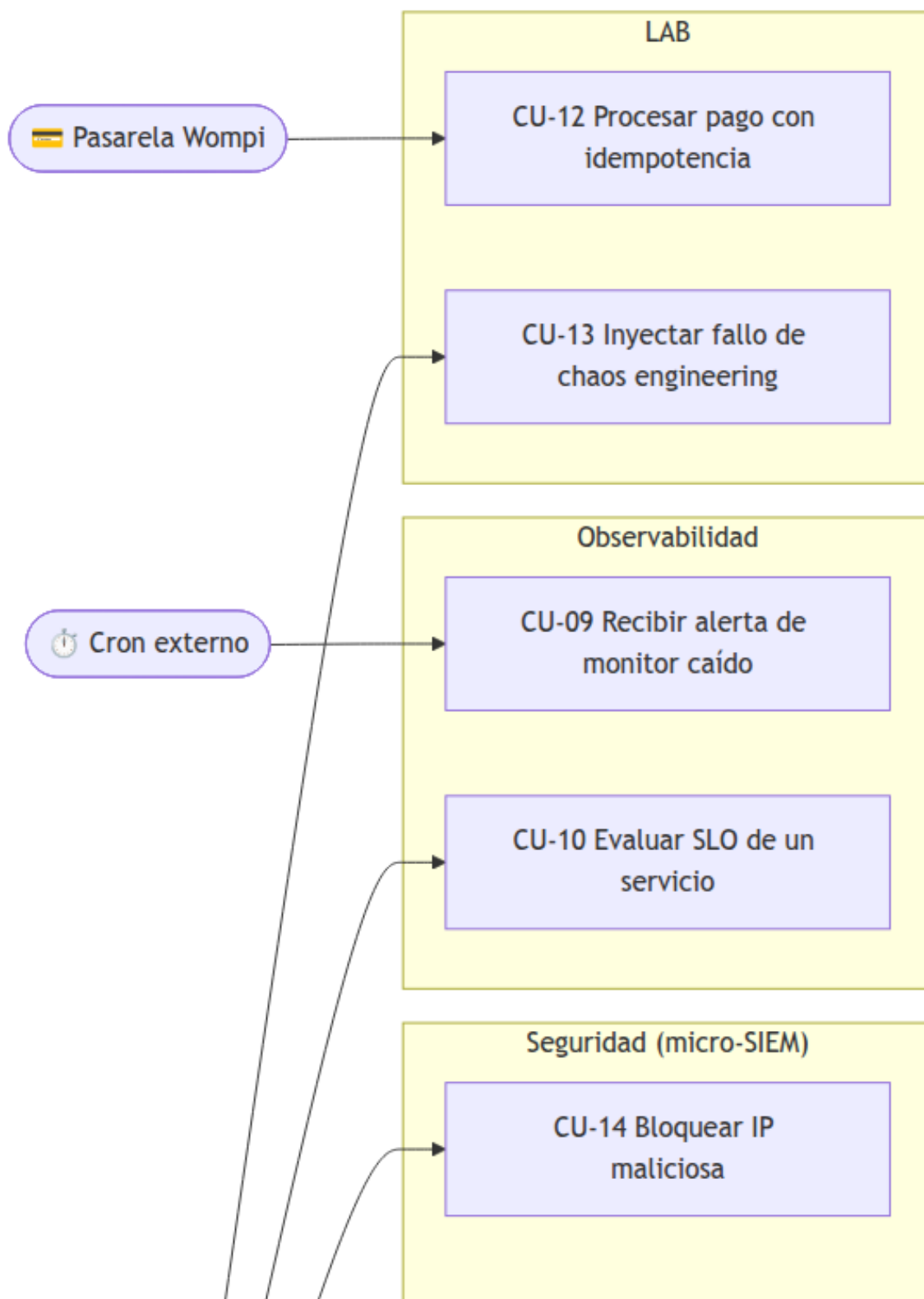
3. Vistas de la Arquitectura

3.1 Vista de casos de uso

El sistema define 6 actores y 18 casos de uso principales, agrupados en 8 módulos funcionales reales del proyecto. Los actores, casos de uso y requerimientos funcionales relacionados están versionados como código en `src/data/documentacion.ts` y se navegan en producción en `/docs/casos-de-uso`.

Actor	Descripción
Visitante público	Cualquier persona que navega el sitio público sin autenticarse.
Administrador (Mike)	Único usuario con acceso al panel <code>/admin</code> , autenticado con GitHub OAuth vía <code>allowlist</code> .
Cliente	Persona de negocio de un proyecto gestionado; interactúa vía portal, contacto o presentaciones.
Cron externo	Disparador automático periódico (<code>cron-job.org</code> / <code>Vercel Cron</code>).
Pasarela de pagos (Wompi)	Sistema externo que envía webhooks de eventos de pago.
Buscador	Rastreador que consume sitemap, RSS y recibe notificaciones IndexNow.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

Diagrama de casos de uso general, agrupado por los 8 módulos funcionales del sistema.

3.1.1 Módulo: Sitio público

Actor principal: Visitante público.

CU-01 Explorar proyectos públicos: navega el listado y entra al detalle de un proyecto.

CU-02 Enviar mensaje de contacto: completa el formulario y el mensaje queda en la bandeja del CRM.

CU-03 Consultar estado del sistema: revisa uptime, incidentes activos y latencia en tiempo real.

3.1.2 Módulo: Autenticación y sesiones

Actor principal: Administrador.

CU-04 Iniciar sesión como administrador: se autentica con GitHub y accede si su login está en la allowlist (<<extends>> Rechazar login fuera de la allowlist).

CU-05 Gestionar sesiones de dispositivo: revisa dispositivos con sesión activa y revoca los que no reconoce.

3.1.3 Módulo: CRM

Actor principal: Administrador; actor secundario: Cliente.

CU-06 Registrar y dar seguimiento a un proyecto (<<include>> Registrar interacción, <<include>> Documentar ADR).

CU-07 Elaborar un briefing de cliente: objetivo, alcance, presupuesto e ítems antes de iniciar el proyecto.

CU-16 Presentar un proyecto a un cliente: control remoto de avance de diapositivas en tiempo real.

3.1.4 Módulo: Finanzas

Actor principal: Administrador.

CU-08 Registrar costos y calcular P&L (<<include>> Calcular P&L del proyecto, <<extends>> Excluir costo sin tasa de cambio).

3.1.5 Módulo: Observabilidad

Actor principal: Cron externo; actor secundario: Administrador.

CU-09 Recibir alerta de monitor caído (<<include>> Abrir incidente, <<include>> Notificar caída por push).

CU-10 Evaluar SLO de un servicio: define objetivo y ventana, consulta el presupuesto de error restante.

3.1.6 Módulo: LAB

Actor principal: Pasarela de pagos (Wompi) y Administrador.

CU-12 Procesar un pago con idempotencia (<<extends>> Registrar evento duplicado, <<extends>> Registrar evento fuera de orden).

CU-13 Inyectar un fallo de chaos engineering (<<include>> Aplicar fallo simulado, <<extends>> Botón de pánico).

3.1.7 Módulo: Seguridad (micro-SIEM)

Actor principal: Administrador.

CU-14 Bloquear una IP maliciosa (<<include>> Registrar evento de seguridad, <<extends>> Bloqueo manual).

CU-15 Aplicar rate limiting durable: limita a un cliente que excede el umbral usando estado persistido.

3.1.8 Módulo: Sistema

Actor principal: Administrador; actor secundario: Buscador.

CU-11 Ejecutar backup manual (<<extends>> Backup automático por cron).

CU-17 Indexar contenido nuevo en buscadores: notifica vía IndexNow al publicar contenido.

CU-18 Consultar documentación del proyecto (<<include>> Navegar subpágina, <<extends>> Consultar diagrama).

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

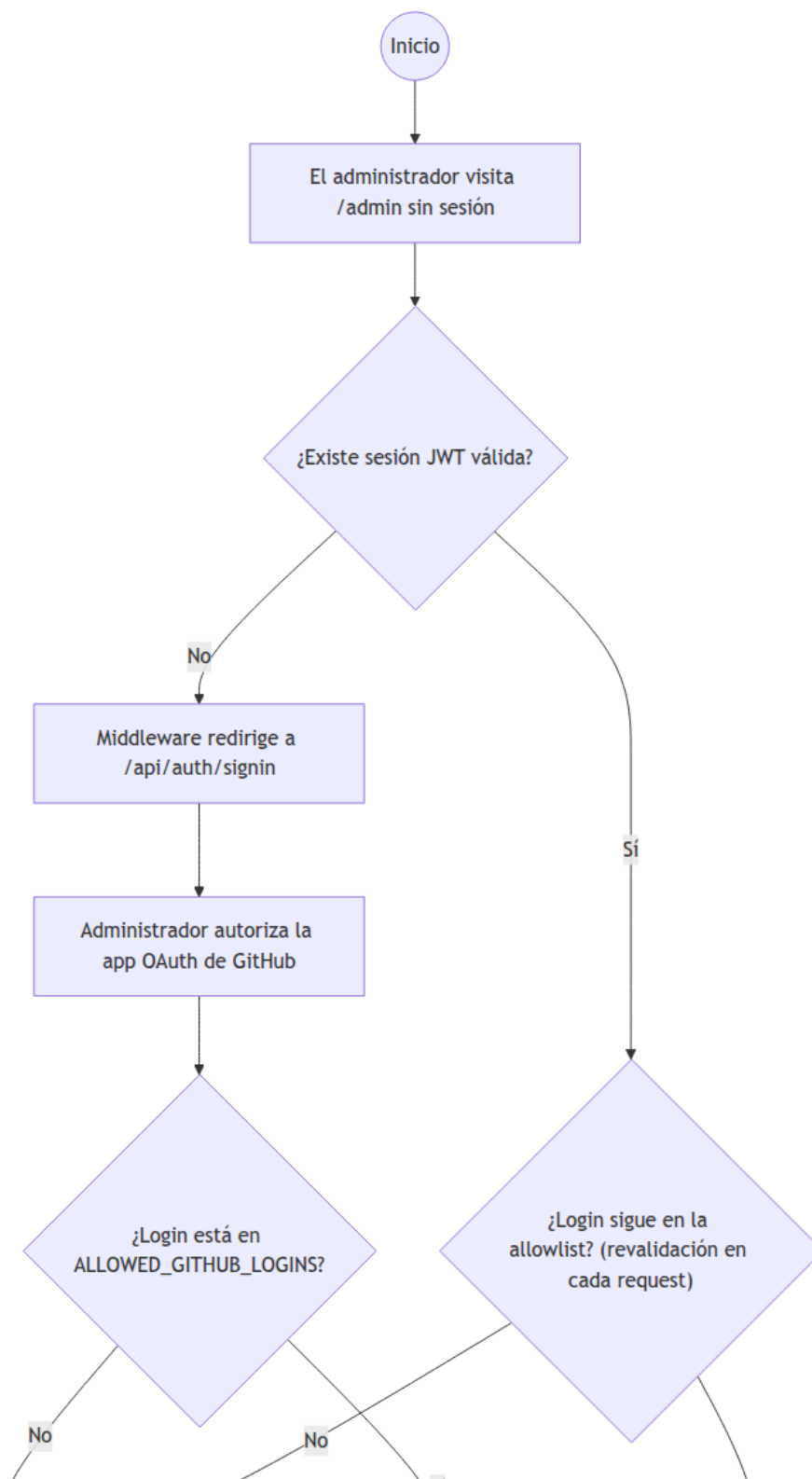
3.2 Vista de procesos

Diagramas de actividades

3.2.1 Módulo Autenticación — Inicio de sesión del administrador (CU-04)

El middleware verifica si existe sesión JWT válida. Sin sesión, redirige a GitHub OAuth; tras la autorización, Auth.js valida el login contra la allowlist ALLOWED_GITHUB_LOGINS. Con sesión existente, la allowlist se revalida en cada request como defensa en profundidad.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

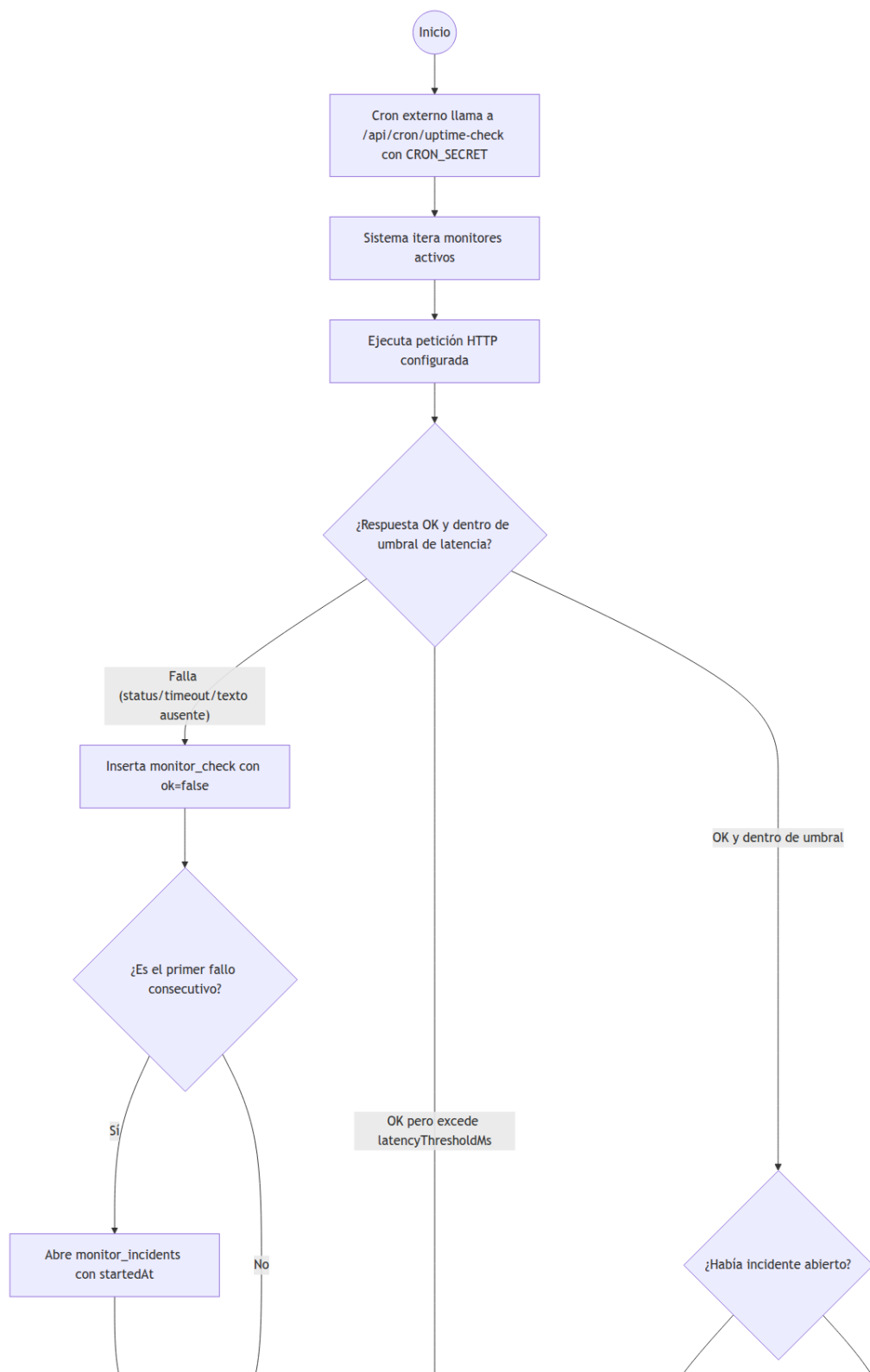


	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

3.2.2 Módulo Observabilidad — Chequeo de disponibilidad de un monitor (CU-09)

El cron externo dispara el chequeo con Bearer CRON_SECRET. Ante un fallo, se distingue entre primer fallo consecutivo (abre un incidente) y fallos subsecuentes (mismo incidente). Una respuesta lenta marca degradación sin abrir incidente; la recuperación cierra el incidente.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026

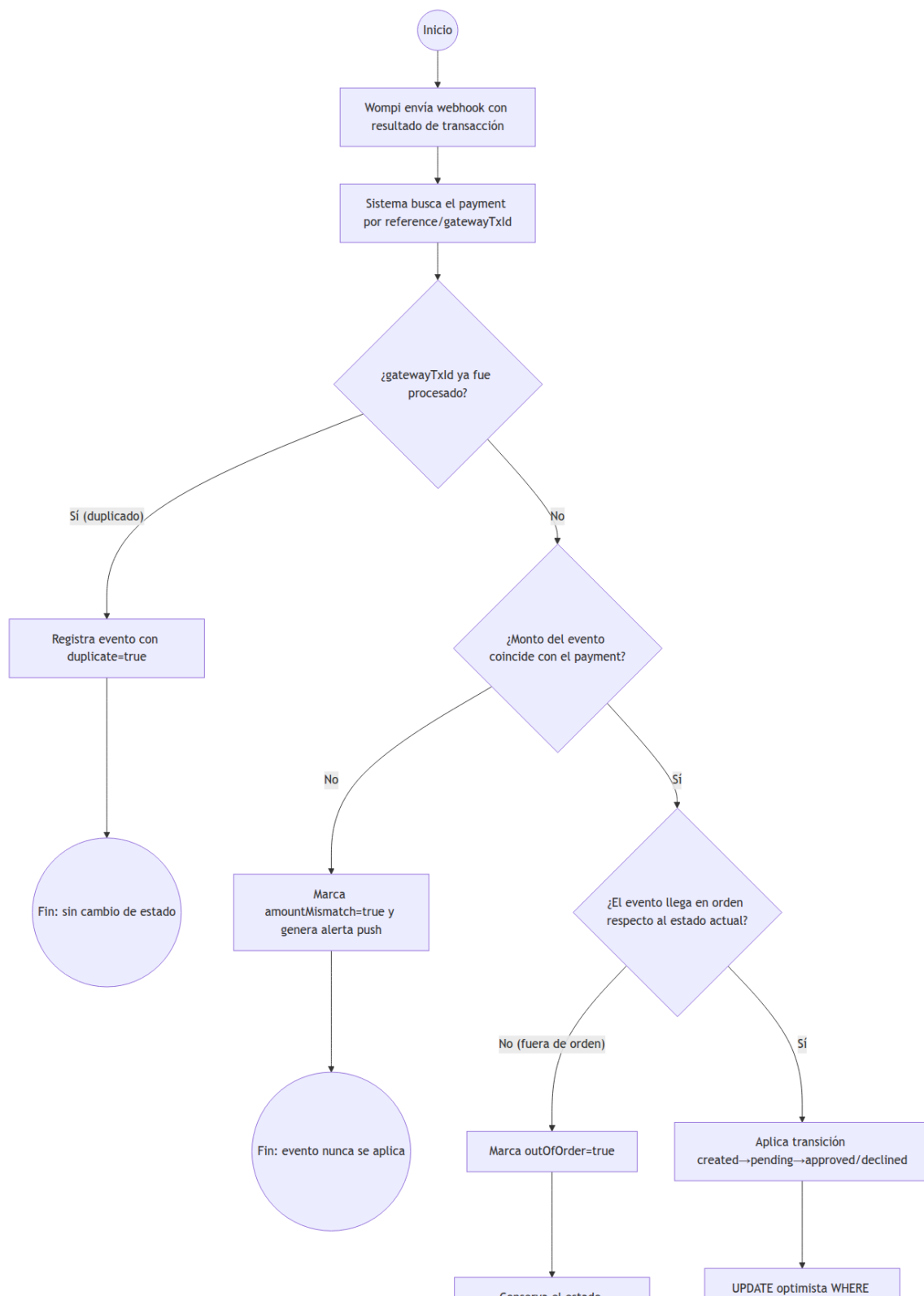


	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

3.2.3 Módulo LAB — Procesamiento de un webhook de pago (CU-12)

Cada evento del gateway se registra siempre en la bitácora, incluso si es duplicado o fuera de orden. Solo se aplica una transición de estado si el evento es nuevo, en orden y el monto coincide exactamente con el del pago original.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

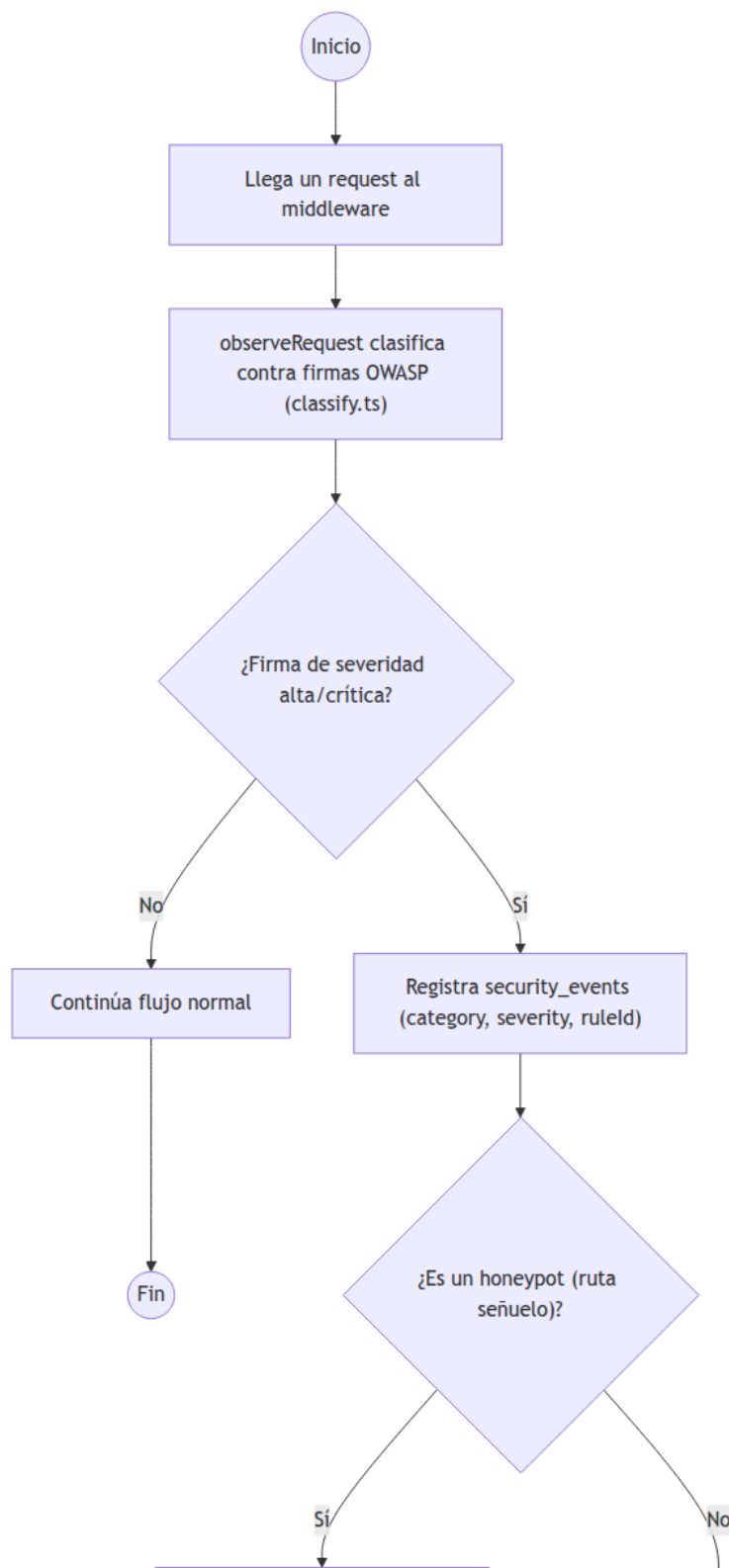


	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

3.2.4 Módulo Seguridad — Clasificación y bloqueo de tráfico hostil (CU-14)

El sensor clasifica cada request contra firmas OWASP. Un hit sobre un honeypot bloquea la IP inline, sin esperar al cron. Cualquier fallo de lectura de base de datos deja pasar el request (fail-open).

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

3.2.5 Módulo CRM — Registrar y dar seguimiento a un proyecto (CU-06)

El administrador crea el proyecto desde /admin/projects (requiere slug y title), estado 'activo' y no visible al público.

Registra una interacción de seguimiento (llamada, reunión, tarea) con próxima acción.

Documenta una decisión de arquitectura (ADR): contexto, decisión, justificación, estado.

Opcionalmente marca el ADR como público para exponerlo en la vitrina del proyecto.

3.2.6 Módulo Finanzas — Registrar costos y calcular P&L (CU-08)

El administrador registra un servicio o costo (ciclo, moneda, quién paga y a quién se factura).

projectPnL() calcula el costo mensual equivalente en USD y lo proyecta desde el inicio del proyecto.

Un costo en moneda sin tasa de cambio configurada se excluye del total y se marca como advertencia.

3.2.7 Módulo Sistema — Backup manual/automático (CU-11)

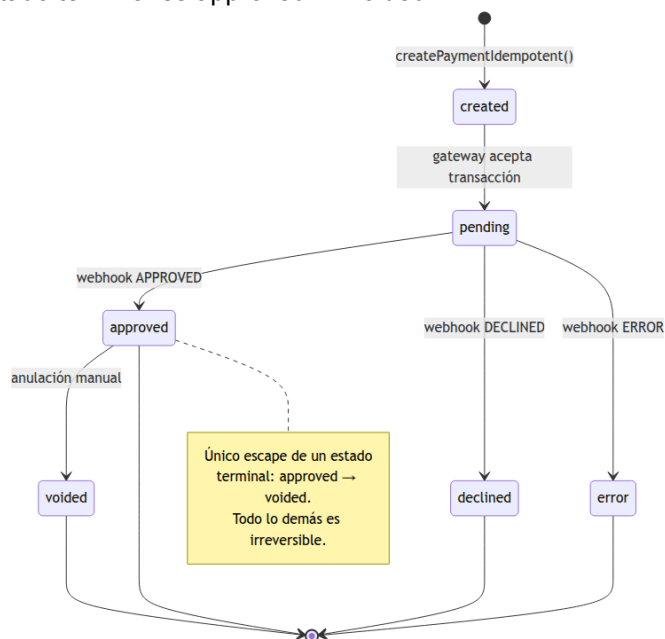
El administrador dispara el backup desde /admin/backup, o el cron externo lo hace automáticamente.

runBackup() arma un dump JSON de las tablas de negocio y lo sube a Vercel Blob con acceso privado.

Diagramas de estados

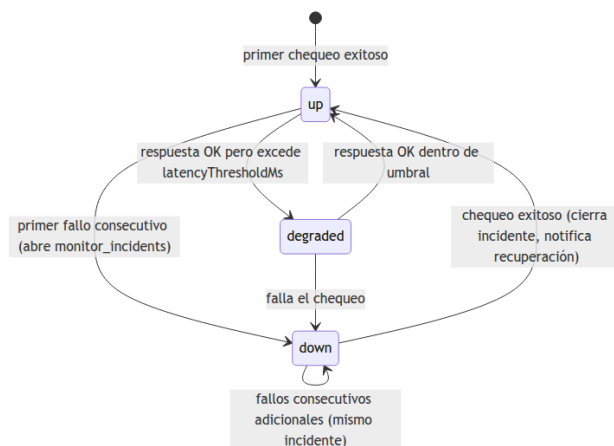
3.2.8 Estados de un pago (módulo LAB)

Máquina de estados pura (payments-state.ts), sin dependencias de base de datos. El único escape permitido desde un estado terminal es approved → voided.



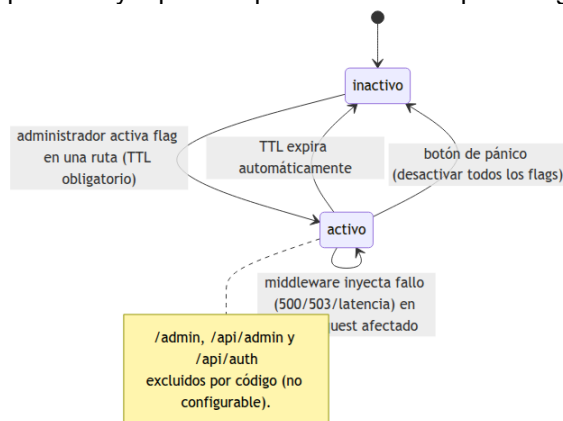
3.2.9 Estados de un monitor (módulo Observabilidad)

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026



3.2.10 Estados de un flag de chaos engineering (módulo LAB)

Todo flag tiene TTL obligatorio (máximo 15 minutos) y puede desactivarse vía un botón de pánico global. Las rutas /admin, /api/admin y /api/auth quedan excluidas por código.



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

3.3 Vista lógica

Diagrama de clases (entidades de dominio)

El esquema completo vive en src/db/schema.ts (Drizzle ORM, ~33 tablas). El siguiente diagrama muestra las entidades centrales y sus relaciones principales, agrupadas por los dominios de negocio, pagos, observabilidad, seguridad y portal de clientes.

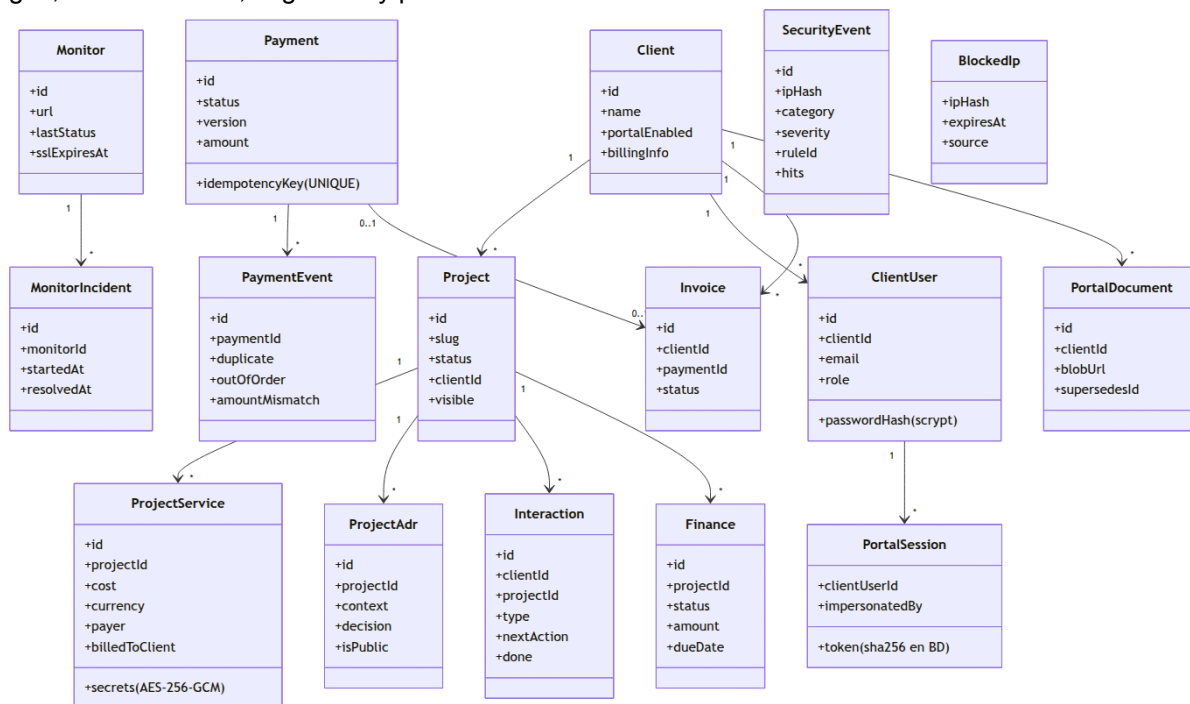
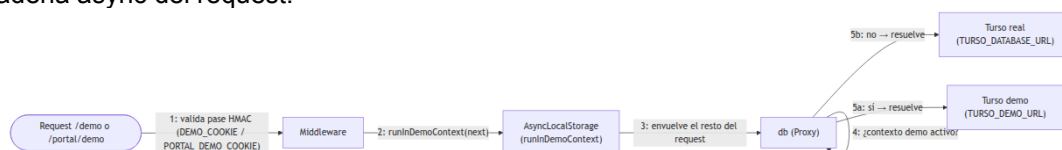


Diagrama de comunicación

3.3.1 Módulo Sistema — Resolución de contexto demo vs. real

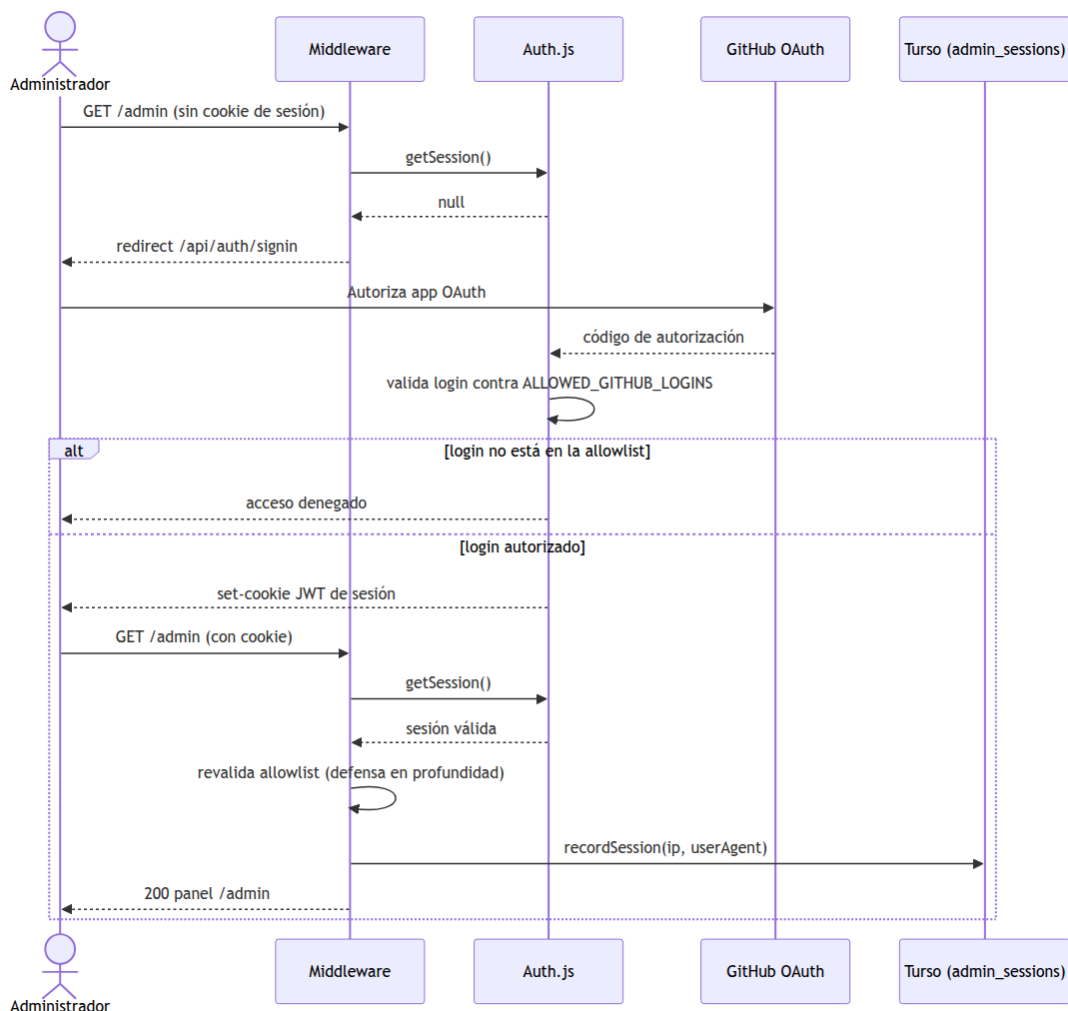
El objeto db exportado por src/db/index.ts es un Proxy que resuelve, en cada acceso, si debe apuntar a la base de datos real o a la demo, según el contexto propagado por AsyncLocalStorage a lo largo de la cadena async del request.



Diagramas de secuencia

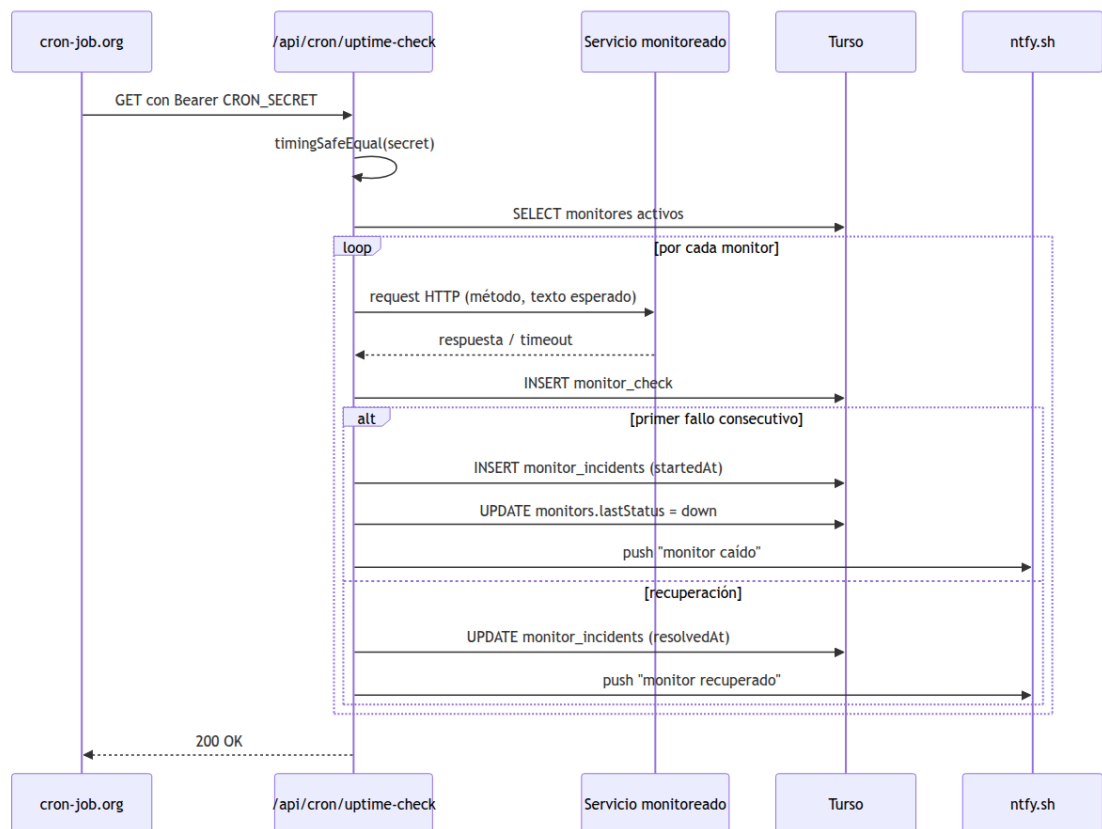
3.3.2 Módulo Autenticación — Inicio de sesión del administrador (CU-04)

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026



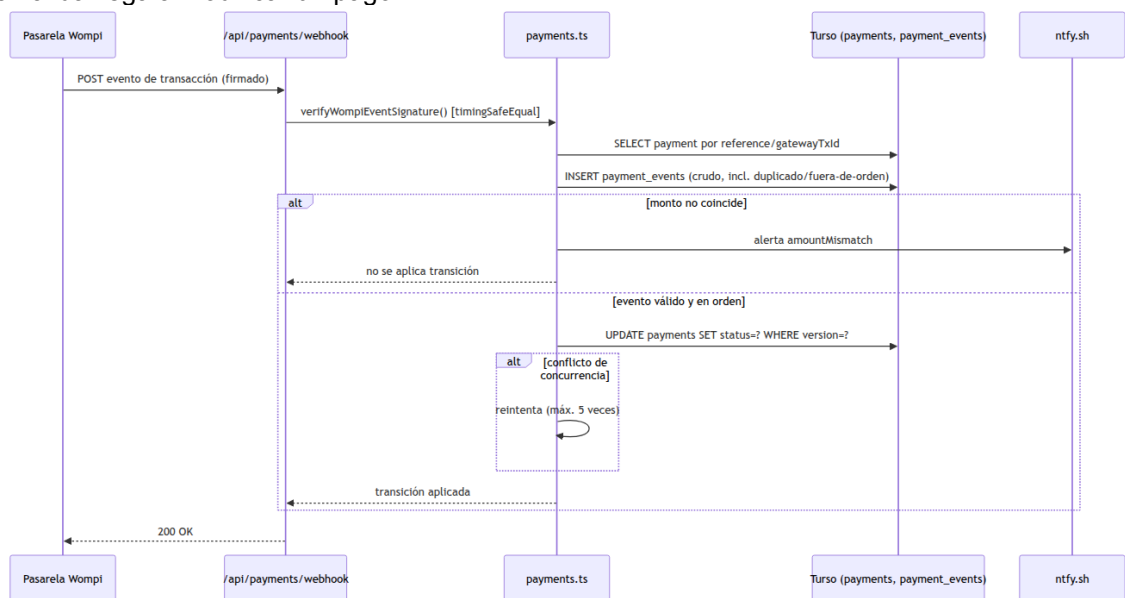
3.3.3 Módulo Observabilidad — Alerta de monitor caído (CU-09)

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026



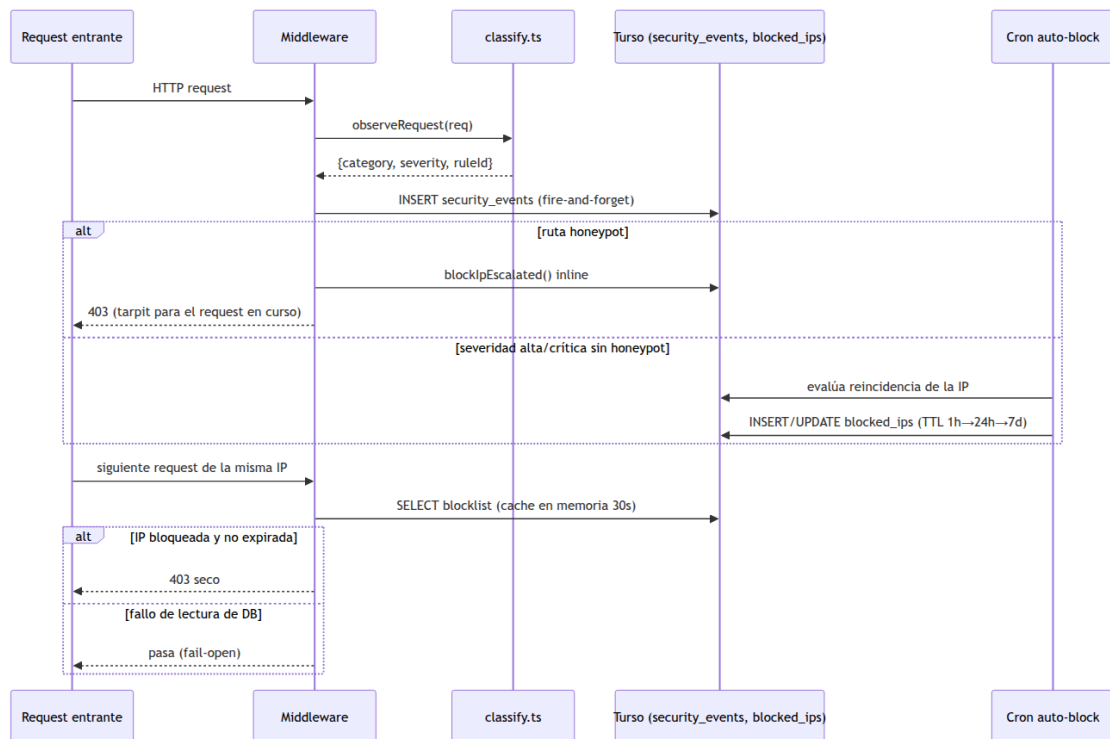
3.3.4 Módulo LAB — Webhook de pago con idempotencia (CU-12)

La verificación de firma (timingSafeEqual) ocurre antes de tocar cualquier estado; ningún evento sin firma válida llega a modificar un pago.

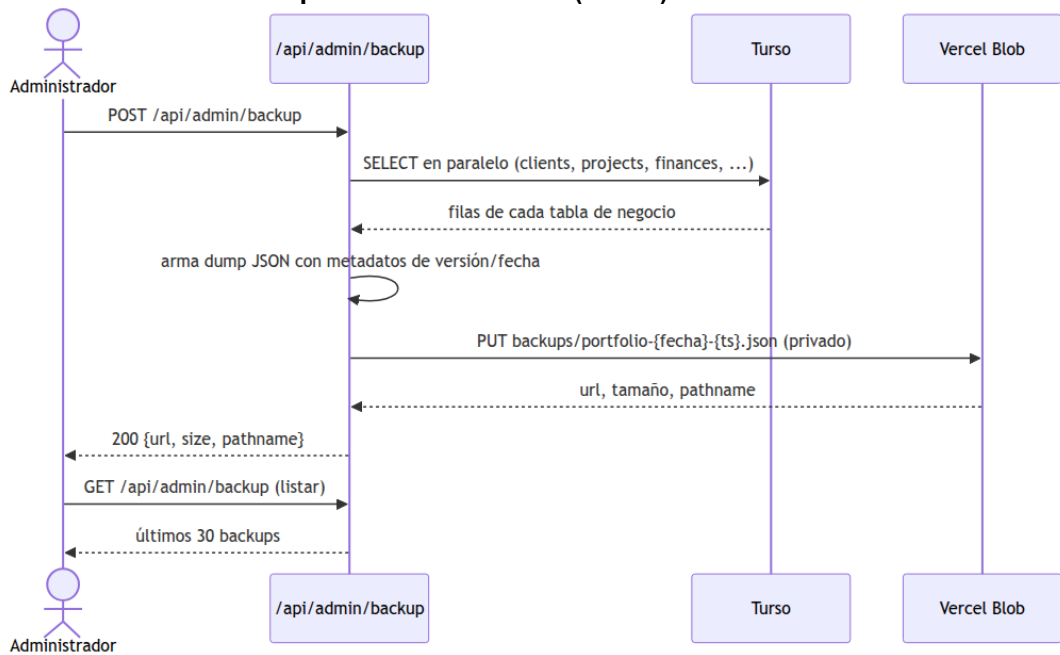


3.3.5 Módulo Seguridad — Detección y bloqueo de una IP maliciosa (CU-14)

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026



3.3.6 Módulo Sistema — Backup manual/automático (CU-11)



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026

3.4 Vista de implementación

Diagrama de componentes

El middleware es el único punto de entrada para toda request: aplica el sensor de seguridad, el rate limiting, la blocklist y decide cuál de los tres sistemas de autenticación aplica según la ruta, antes de delegar en las páginas SSR o los endpoints de API.

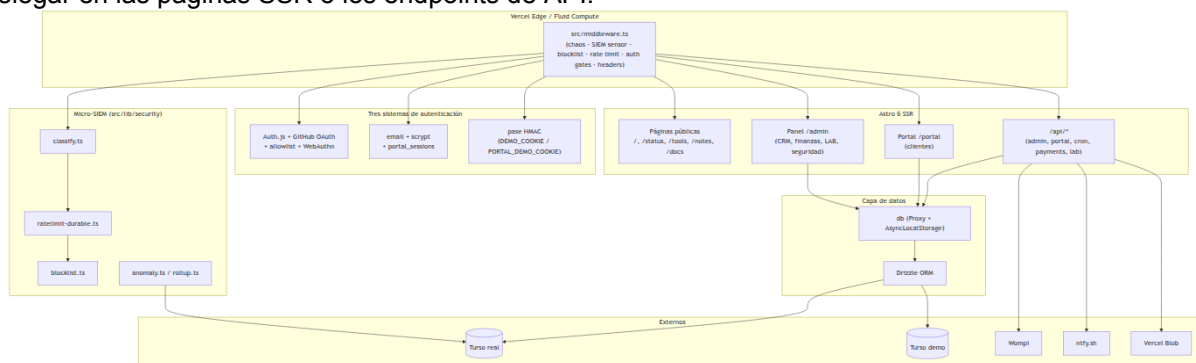
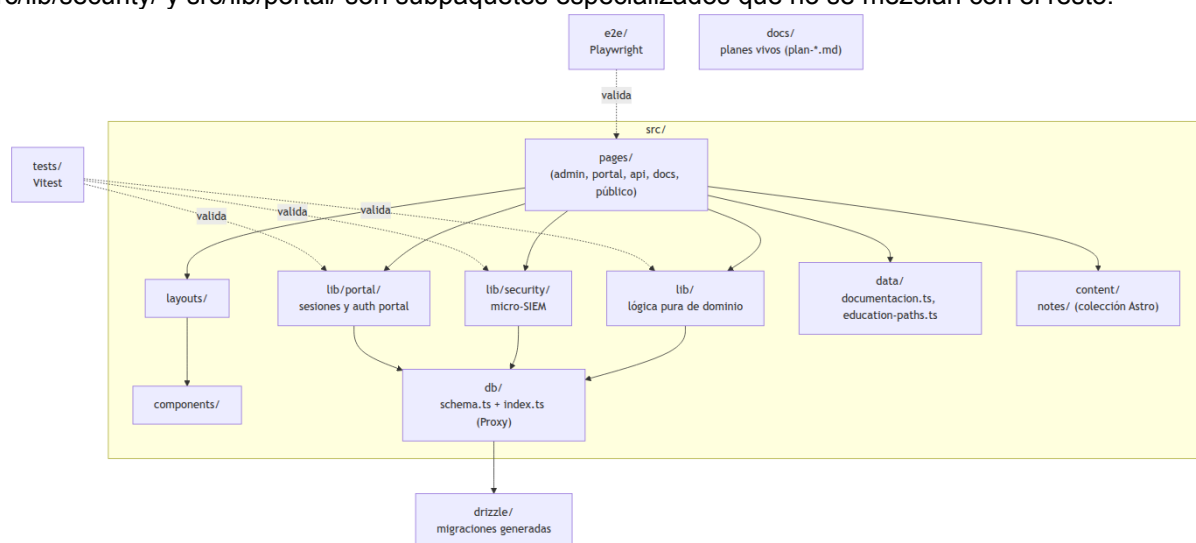


Diagrama de paquetes

src/lib/ concentra la lógica de dominio pura (testable sin base de datos siempre que es posible); src/lib/security/ y src/lib/portal/ son subpaquetes especializados que no se mezclan con el resto.

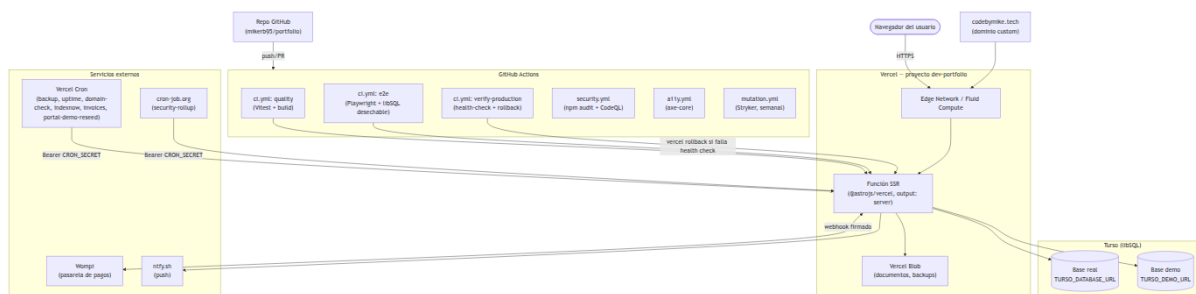


3.5 Vista de despliegue

Diagrama de despliegue

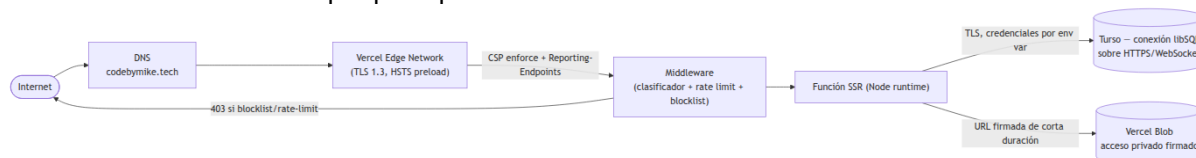
El sistema se despliega en Vercel (proyecto dev-portfolio) bajo el dominio codebymike.tech. El pipeline de GitHub Actions corre pruebas de calidad, end-to-end, seguridad, accesibilidad y mutation testing; en push a main, un job adicional verifica el health check post-deploy y ejecuta rollback automático si el despliegue resulta insano.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026



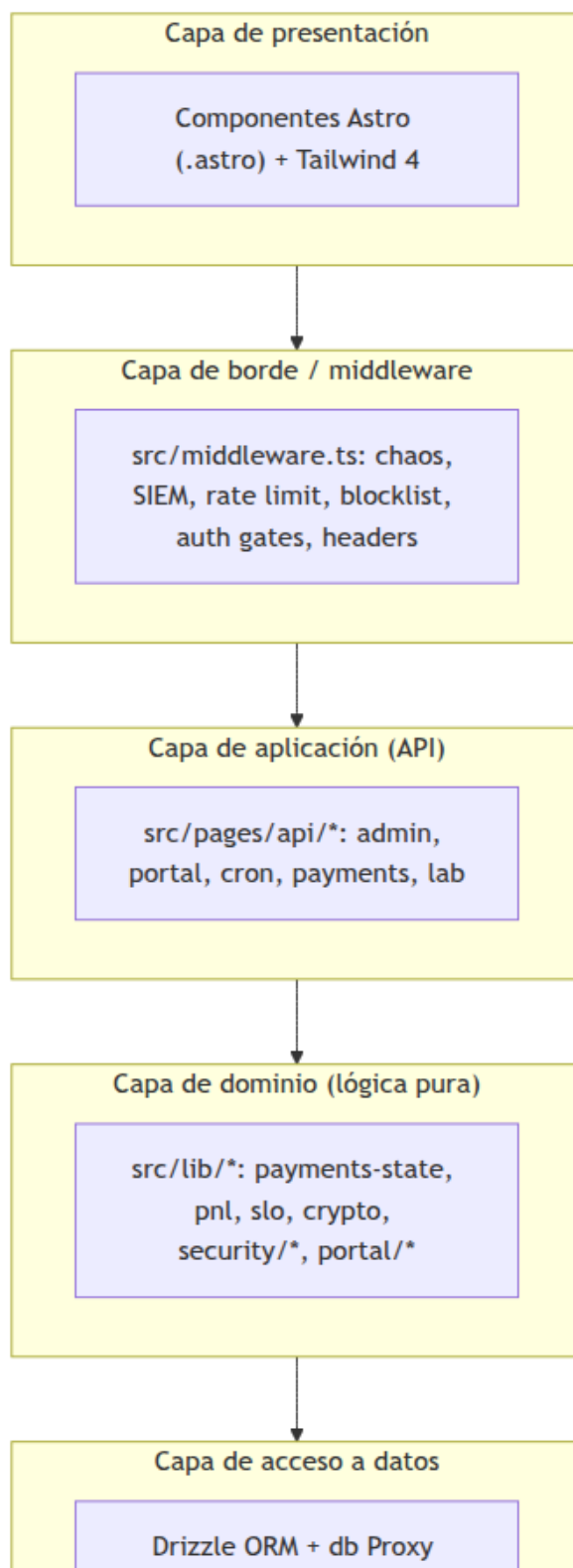
Infraestructura de red

Todo tráfico entra por la red de borde de Vercel (TLS 1.3, HSTS con preload) antes de llegar al middleware, que decide si continúa hacia la función SSR o se corta con un 403. El acceso a documentos privados en Vercel Blob siempre pasa por una URL firmada de corta duración.



3.6 Arquitectura en capas

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

Cuadro de tecnologías por capa

Capa	Tecnologías
Presentación	Astro 6 (componentes .astro), Tailwind 4, reveal.js (presentador de slides)
Borde / middleware	Astro middleware sobre Vercel Fluid Compute (Node.js runtime completo)
Aplicación (API)	Astro API routes (src/pages/api/*), Zod para validación de entrada
Dominio (lógica pura)	TypeScript sin dependencias externas en src/lib/*
Acceso a datos	Drizzle ORM + @libsql/client, patrón Proxy + AsyncLocalStorage
Persistencia	Turso (libSQL) — instancia real y demo; Vercel Blob para binarios privados

Cuadro de patrones de diseño por capa

Capa	Patrón aplicado
Borde / middleware	Chain of Responsibility (chaos → sensor → blocklist → rate limit → auth gate → headers)
Aplicación (API)	Idempotency Key, Circuit-breaker parcial vía fail-open
Dominio	State Machine pura (payments-state.ts), Strategy (clasificador de firmas)
Acceso a datos	Proxy + Context propagation (db Proxy resuelto por AsyncLocalStorage)
Persistencia	Optimistic concurrency control (UPDATE ... WHERE version = ?)
Transversal	Observer/Sensor (registro fire-and-forget de eventos de seguridad)

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
	Proyecto: CodeByMike	
Código:	Versión:1.0	Fecha: 27/07/2026

3.7 Vista de datos

Modelo Relacional del portfolio

El modelo relacional (Drizzle ORM sobre SQLite/Turso, ~33 tablas) se organiza en siete dominios funcionales.

1. Negocio / CRM

clients: empresa/cliente, con portalEnabled y billingInfo (JSON).

projects: proyecto gestionado, con slug, status y clientId → clients.

interactions: bitácora de seguimiento comercial con recordatorios.

briefings / briefing_items: documento de alcance por proyecto.

2. Infraestructura y costos

project_services: costo por servicio, con secrets cifrados AES-256-GCM, payer y billedToClient.

project_env_vars, project_contacts, project_adrs, app_settings.

3. Observabilidad de negocio

monitors, monitor_checks (purgado a 90 días), monitor_incidents, web_vitals.

4. Micro-SIEM (seguridad)

security_events (ipHash, category, severity, ruleId, hits), security_rollups, blocked_ips, rate_limit_buckets, security_anomalies, security_findings.

5. Autenticación admin

admin_sessions (revocación de dispositivos), webauthn_credentials (passkeys FIDO2).

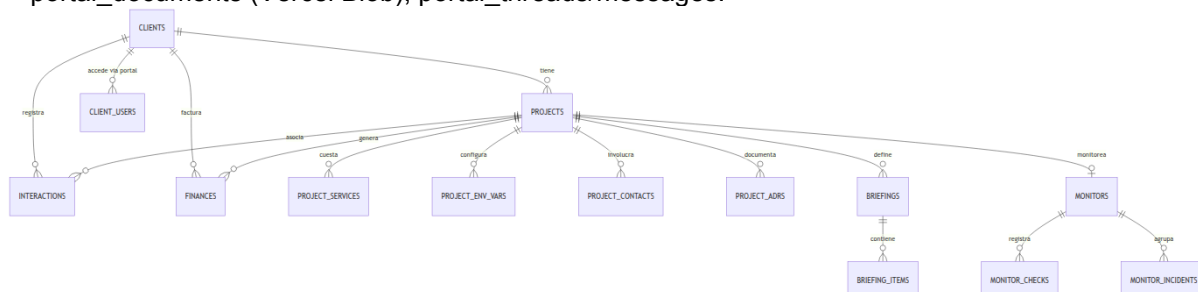
6. Pagos

payments (idempotencyKey único, version optimista), payment_events (bitácora íntegra).

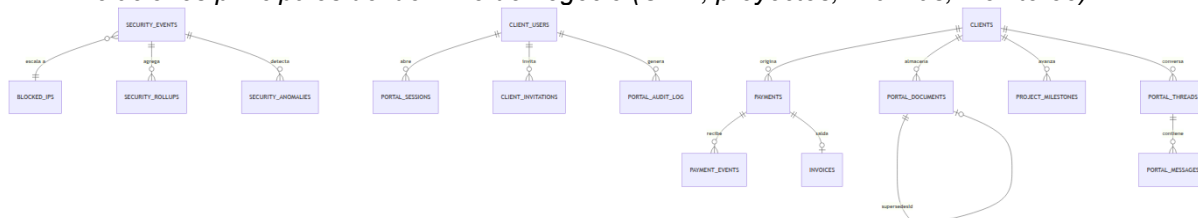
7. Portal de clientes

client_users (script, roles, logout), portal_sessions (revocación inmediata), invoices/invoice_items,

portal_documents (Vercel Blob), portal_threads/messages.



Relaciones principales del dominio de negocio (CRM, proyectos, finanzas, monitoreo).



Relaciones principales de seguridad, pagos y portal de clientes.

Relaciones clave

Cliente – Proyecto: un cliente puede tener varios proyectos gestionados.

Proyecto – Servicios/Costos: cada proyecto acumula los costos base del cálculo de P&L.

Pago – Eventos: cada pago conserva la bitácora completa de todos los eventos de webhook recibidos.

Cliente – Usuario de portal: el aislamiento del portal se resuelve siempre desde la sesión, nunca desde la URL.

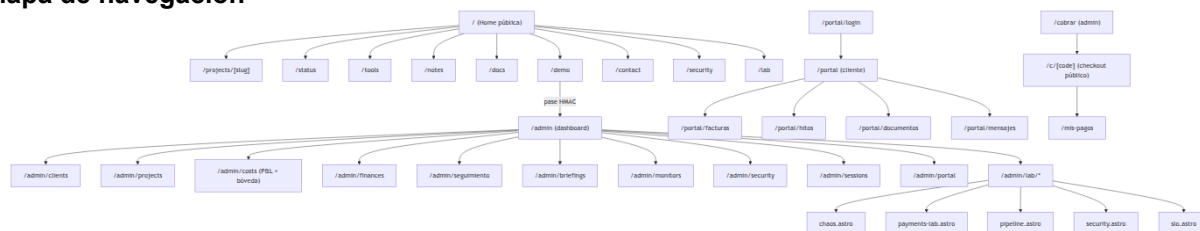
Evento de seguridad – IP bloqueada: la reincidencia escala el TTL de bloqueo (1h → 24h → 7d).

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

4. Definición de Interfaces de Usuario

El sistema expone tres superficies de navegación independientes: el sitio público, el panel administrativo (/admin) y el portal de clientes (/portal), cada una con su propio layout base y su propio esquema de autenticación.

Mapa de navegación



Mapa de navegación: sitio público, panel administrativo y portal de clientes.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

Pantallazo de cada módulo del S.I.
Capturas reales del sitio en ejecución (localhost, datos de demo donde aplica).
Home pública

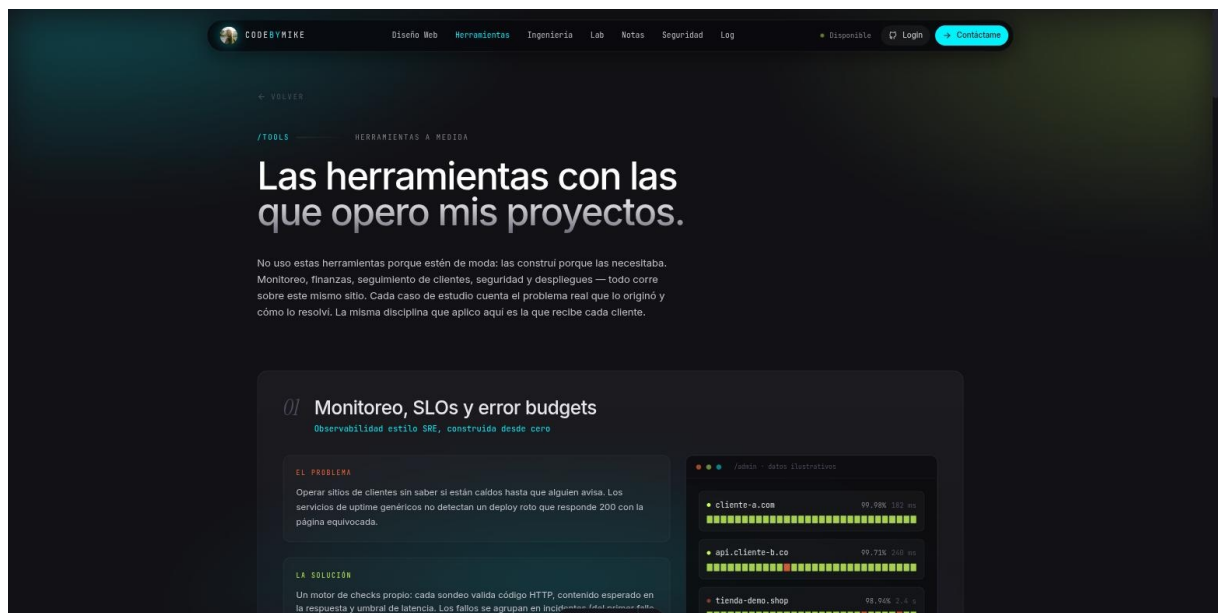


/status — Estado de los servicios

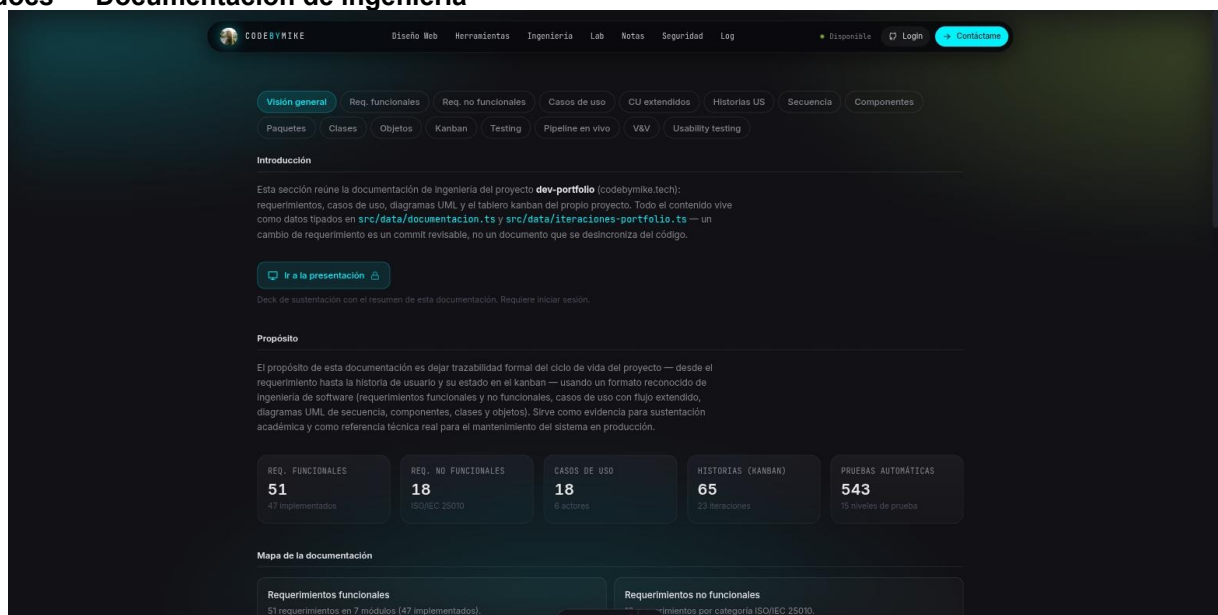


/tools — Vitrina de herramientas

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

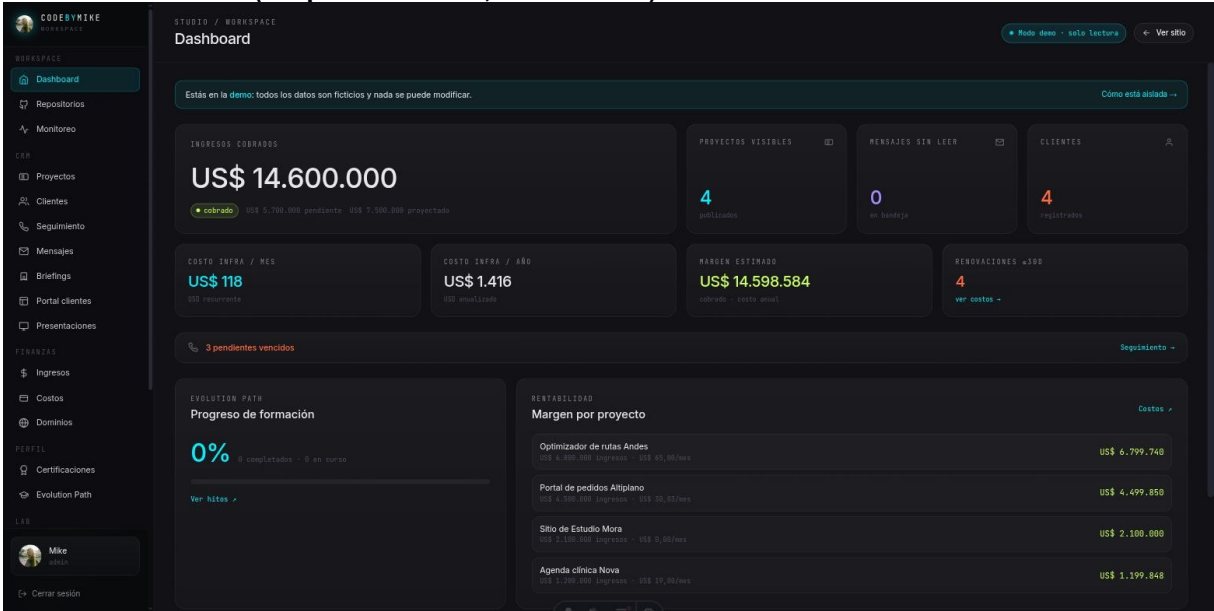


/docs — Documentación de ingeniería

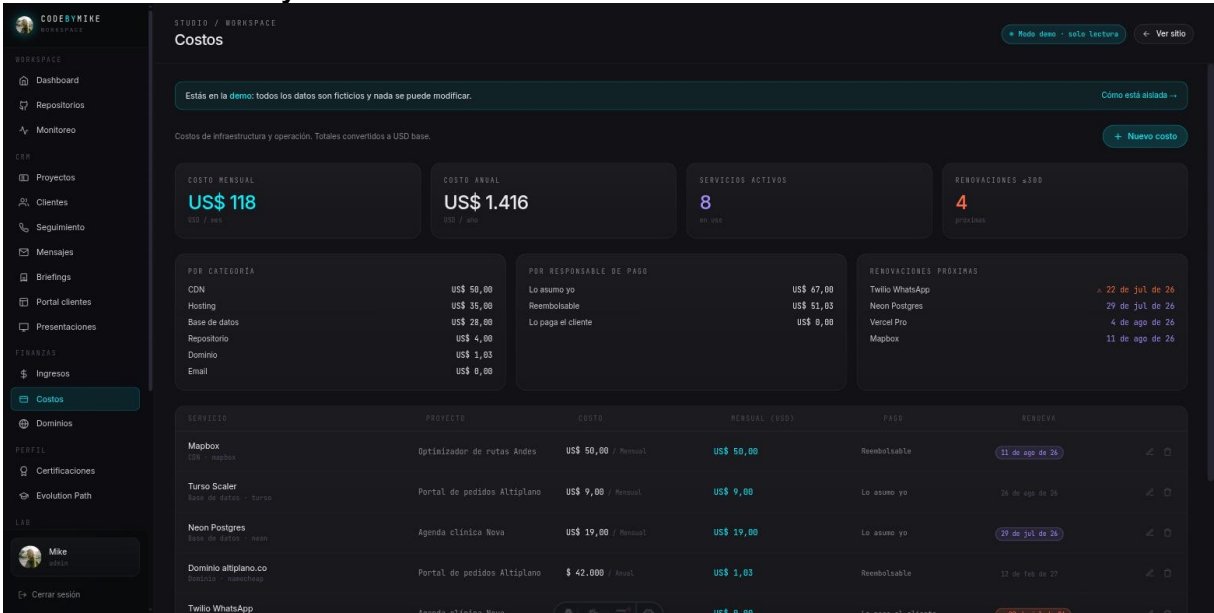


	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

/admin — Dashboard (vía pase de demo, solo lectura)

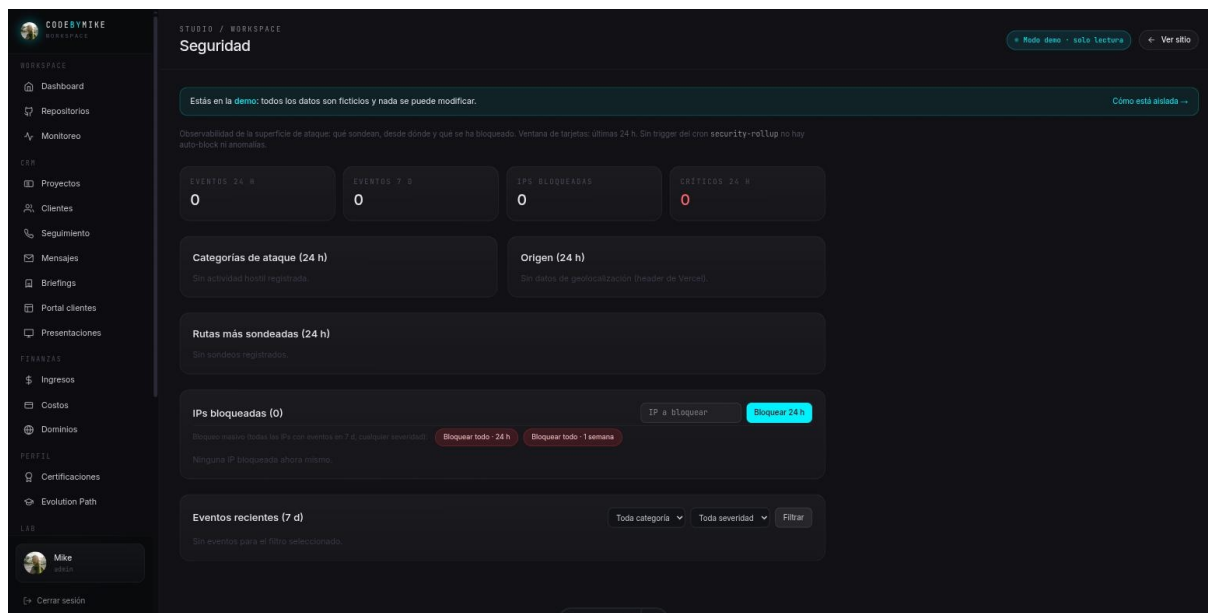


/admin/costs — Costos y P&L



/admin/security — Panel del micro-SIEM

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

/admin/monitors — Monitoreo de disponibilidad

CODEBYMIKE

WORKSPACE

WORKSPACE

Dashboard

Repositorios

Monitoreo

CER

Proyectos

Clientes

Seguimiento

Mensajes

Briefings

Portal clientes

Presentaciones

FINANZAS

Ingresos

Costos

Dominios

PERFIL

Certificaciones

Evolution Path

LIB

Mike

Cerrar sesión

STUDIO / WORKSPACE

Monitoreo

Estás en la demo: todos los datos son ficticios y nada se puede modificar.

Cómo está aislada -->

Estado de tus servicios. El sondes lo dispara un cron externo (cron-job.org) que pega cada pocos minutos a /api/cron/uptime-check. Aquí ves uptime, latencia, certificados SSL e incidentes.

Cron externo >

+ Monitor

Chequear ahora

+ Email via configuración

+ Push via configuración

CADIDOS

0

DEGRADADOS

1

OPERATIVOS

3

Pruebas en vivo

Realiza las siguientes pruebas contra un dominio: disponibilidad, TLS, DNS, cobertura de seguridad, robots.txt y vencimiento del dominio.

codebymike.tech · https://tu-proyecto.com

Ejecutar pruebas

Portal Altiplano

https://altiplano.example · Portal de pedidos Altiplano · hace 7d · 10ms

100%

Agenda Nova

https://agenda.deltasnova.example · Agenda clínica Nova · hace 7d · 20ms

99.6%

API Rutas Andes

https://api.rutas.example/health · Optimizador de rutas Andes · hace 7d · 100ms

98.5%

Estudio Mora

https://estudiomora.example · Sitio de Estudio Mora · hace 7d · 10ms

99.3%

/admin/lab/pipeline — Pipeline CI/CD

CODEBYMIKE

WORKSPACE

WORKSPACE

Dashboard

Repositorios

Monitoreo

CER

Proyectos

Clientes

Seguimiento

Mensajes

Briefings

Portal clientes

Presentaciones

FINANZAS

Ingresos

Costos

Dominios

PERFIL

Certificaciones

Evolution Path

LIB

Mike

Cerrar sesión

STUDIO / WORKSPACE

Pipeline CI/CD

Estás en la demo: todos los datos son ficticios y nada se puede modificar.

Cómo está aislada -->

Cada push a main dispara test --> build --> deploy. Tras el deploy, el pipeline verifica /api/health en producción y hace rollback automático si la versión nueva no está sana.

🔍 🔄 Rolling

Sin mutation score todavía. Job manual/benchmark: workflow_dispatch en mutation.yml o npm run test:mutation local.

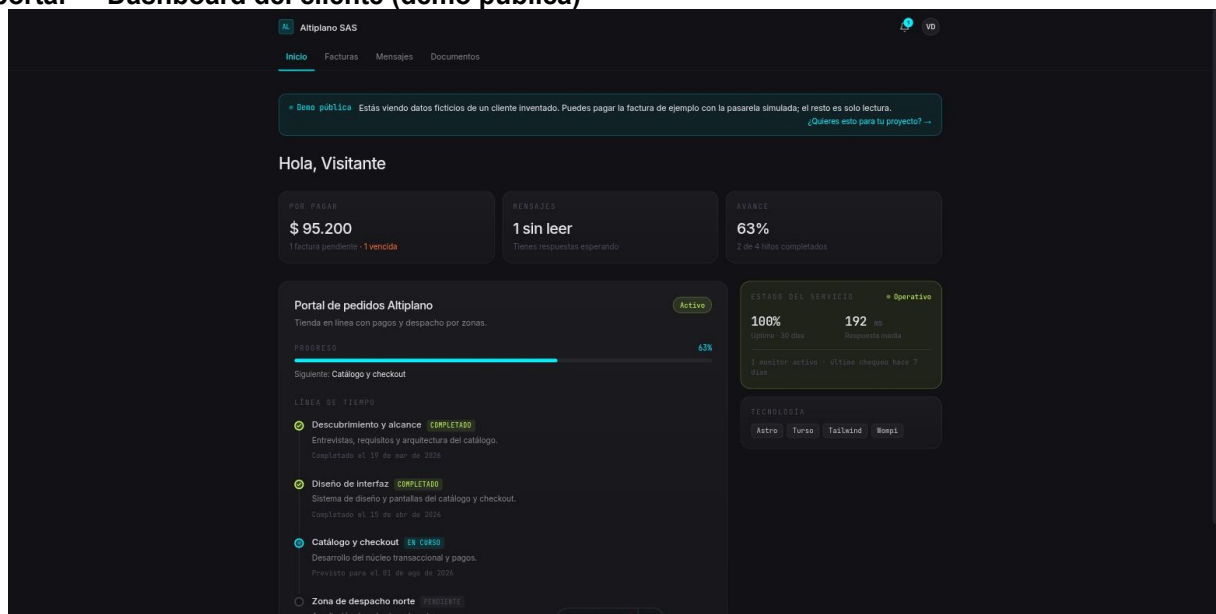
COMMIT	RESULTADO	TESTS	COBERTURA	HEALTH	DURACIÓN	FECHA
a1b2c3d main	Éxito	286 ✓	55%	●	90s	16 de jul, 01:12 a. m.
4e5f6a7 main	Éxito	286 ✓	55.2%	●	102s	14 de jul, 01:12 a. m.
8b9c0d1 main	Éxito	286 ✓	55.4%	●	114s	12 de jul, 01:12 a. m.
2a3f4a5 main	Éxito	286 ✓	55.6%	●	128s	10 de jul, 01:12 a. m.
6b7c8d9 main	Rollback	286 ✓ 2 ✗	55.8%	●	138s	8 de jul, 01:12 a. m.
0e1f2a3 main	Éxito	286 ✓	56%	●	150s	6 de jul, 01:12 a. m.
4b5c6d7 main	Éxito	286 ✓	56.2%	●	162s	4 de jul, 01:12 a. m.

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

/portal/login — Acceso al portal de clientes

escribirme.' At the bottom, there's a link '¿Solo quieres ver cómo es el portal?' and a button 'Entrar a la demo pública'. At the very bottom, a small link 'Acceso privado para clientes: codebyvicio.team' is visible." data-bbox="130 212 895 483"/>

/portal — Dashboard del cliente (demo pública)



	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

5. Características Generales de Calidad

5.1 Tamaño y performance

El sistema corre como una función SSR en Vercel (Fluid Compute, reutilización de instancias entre requests concurrentes), lo que reduce cold starts frente al modelo serverless tradicional. Los checks de monitoreo y eventos de seguridad crudos se purgan a los 90 días, conservando los agregados para tendencias históricas.

El sensor de seguridad clasifica cada request en memoria y escribe el evento de forma fire-and-forget, de modo que la latencia añadida es imperceptible. La blocklist y los flags de chaos se cachean en memoria por 30 segundos.

5.2 Calidad

La calidad se sostiene con un pipeline de CI que corre en cada push/PR: pruebas unitarias (Vitest) con cobertura, pruebas end-to-end (Playwright) contra bases de datos libSQL desechables, análisis de seguridad estático (npm audit + CodeQL), auditoría de accesibilidad (axe-core) y mutation testing (Stryker) semanal.

5.3 Usabilidad

El panel administrativo es operable desde móvil con un drawer de navegación colapsable. La documentación de ingeniería (/docs) es navegable y está tipada como código, evitando la desincronización habitual entre documentación y sistema real.

5.4 Eficiencia

Las rutas públicas GET usan Cache-Control: public, s-maxage=300, stale-while-revalidate=86400 aplicado centralmente por el middleware. Las rutas privadas se sirven siempre sin caché. El rate limiting durable opera en dos capas (memoria por instancia + Turso).

5.5 Seguridad

El sistema implementa tres esquemas de autenticación completamente separados, sin compartir cookies ni lógica entre sí. Todos los secretos de servicios se cifran en reposo con AES-256-GCM. El micro-SIEM clasifica tráfico hostil con enforcement fail-open. CSP en modo enforce con reporting, HSTS con preload y Permissions-Policy restrictiva se aplican en toda ruta privada.

5.6 Confiabilidad

Los pagos usan una clave de idempotencia única: un mismo idempotencyKey nunca genera dos cobros. La máquina de estados de pagos no retrocede ante eventos duplicados o fuera de orden. El pipeline de despliegue ejecuta un health check post-deploy y revierte automáticamente si el sitio no responde sano.

5.7 Mantenibilidad

Los requerimientos, casos de uso y RNF del propio sistema están definidos como código TypeScript tipado, no como documentos externos desincronizables. Cada decisión técnica relevante por proyecto queda documentada como ADR. Las migraciones de base de datos son siempre aditivas.

Evidencia técnica: normas y estándares aplicables

A continuación se documentan los estándares que enmarcan las decisiones de arquitectura de seguridad, calidad y protección de datos del sistema.

Norma 1: ISO/IEC 27001 — Gestión de Seguridad de la Información

Establece los requisitos para un sistema de gestión de seguridad de la información (SGSI), clave para garantizar confidencialidad, integridad y disponibilidad de los datos.

Aplicación en el sistema:

Autenticación y control de acceso: allowlist explícita, WebAuthn/FIDO2, scrypt para contraseñas del portal.

Cifrado de datos: AES-256-GCM en reposo; TLS/HTTPS en tránsito.

Gestión de riesgos: micro-SIEM propio con clasificación de amenazas y detección de anomalías.

Norma 2: ISO/IEC 25010 — Calidad del producto de software

Sucesora de ISO/IEC 9126; define características de calidad usadas como marco para catalogar los requerimientos no funcionales de este sistema (sección 1.4).

Aplicación en el sistema:

	SERVICIO NACIONAL DE APRENDIZAJE SENA SISTEMA INTEGRADO DE GESTIÓN PROCEDIMIENTO GESTIÓN DE SISTEMAS DE INFORMACIÓN DOCUMENTO DE ARQUITECTURA	Versión: 1
		Código GTI-F-007
Proyecto: CodeByMike		
Código:	Versión:1.0	Fecha: 27/07/2026

Cada RNF en src/data/documentacion.ts está clasificado según estas categorías, con su mecanismo de verificación documentado.

Evaluación continua vía pipeline de CI: seguridad, accesibilidad y mutation testing.

Norma 3: Ley 1581 de 2012 y Decreto 1377 de 2013 — Protección de Datos Personales (Colombia)

Regulan el manejo, almacenamiento y procesamiento de datos personales en Colombia, incluyendo datos de clientes capturados por el sistema.

Aplicación en el sistema:

Minimización de PII: las IPs se hashean antes de exponerse fuera del panel admin.

Aislamiento de datos por cliente: el portal resuelve el cliente siempre desde la sesión, nunca desde la URL.

Datos de contacto y de clientes almacenados con acceso restringido al administrador autenticado.

Norma 4: OWASP Top 10

Catálogo de referencia de los riesgos de seguridad más críticos en aplicaciones web, usado como marco de clasificación de las firmas del micro-SIEM propio.

Aplicación en el sistema:

classify.ts clasifica requests entrantes contra categorías alineadas a OWASP.

La página pública /security documenta hallazgos reales de auditoría mapeados a categorías OWASP, con su commit de corrección.